

Ten questions to ask before you fix a migration order

v1 · 28 August 2026

A short companion to the migration guidance you are already required to follow. It does not replace it. NIST SP 1800-38, the NCSC roadmap, ETSI TR 103 619, Singapore’s Quantum-Safe Handbook and the FS-ISAC roadmap all tell you to inventory, prioritise, then migrate. This covers the prioritise step, which is where those documents say the least and where the consequences of getting it wrong are largest.

Each question wants a number or a name. None of them is a yes/no. A checklist answered “yes, we have that” is a checklist that has told you nothing.

Before you order anything

1. For what share of the systems your scan found do you have a stated confidentiality lifetime?

Not “do we have a data classification policy” — what fraction of the estate that policy actually reaches. The answer is a percentage.

Good: “412 of 690 locations, 60%.” Bad: “we classify our data.”

answer

2. Which systems have no entry? Name them.

This is the denominator. An ordering computed over the classified part is not an ordering over the estate, and the difference is invisible unless someone writes it down.

answer

On the order itself

3. Is your order derived from something measured, or from a criticality register?

Most published guidance says to start with the most critical systems, and criticality registers are usually inherited from an older risk process. Ask what measurement, if any, sits underneath.

answer

4. Does your order change if the capability arrives in 2035 rather than 2045?

If the answer is no, the order is not conditioned on anything about the threat. It is a ranking of your present opinion of your own systems, which is a different object.

answer

5. For each of your top ten: what is the confidentiality lifetime, and what is the emission rate?

The second one is usually missing. A system that emits a small volume of long-lived data can matter more than one holding a large volume of short-lived data, and criticality does not see the difference.

answer

The part migration does not fix

6. Which systems have a required confidentiality lifetime longer than any assumption you would defend in front of an auditor?

Thirty-year retention protected by an assumption most people would defend for ten is not a migration problem. Migrating it changes which conjecture you rely on, not how long you need the answer to hold.

answer

7. For those, what is the plan other than migration?

There are three, and none is a new algorithm: retain the data for less time, split the secret so that no single location holds it, or do not collect it. All three are unfashionable and all three are cheaper.

answer

8. Have you estimated what has already left?

Migration protects future emission. It does nothing for data already captured. If harvest-now-decrypt-later is in your threat model — Singapore’s handbook names long-lived records as the primary target — the volume already gone is part of the answer, and it does not shrink.

answer

The evidence underneath

9. Can you show the date and scope of the inventory the plan rests on?

Scope means what was looked at and what was not: source, CI, infrastructure-as-code, runtime, hardware, third parties. A plan built on an inventory of unstated scope inherits that silence.

answer

10. Does your scanner report what it could not read?

Ask for the number of targets it attempted and failed to open — permission errors, binaries with no symbols, containers it could not enter, repositories it lacked a token for. If the tool cannot answer, “no findings” and “nothing vulnerable” are the same sentence in your report, and they are not the same fact.

answer

A worked example

One estate, answered. The point is not the figures but their shape: several of the useful answers are admissions, and an admission is still a number you can act on.

1. 412 of 690 detected locations, 60%.
2. legacy/batch, vendor/reporting, ops/telemetry — 278 locations with no entry in the retention schedule. The largest is vendor/reporting, a third-party system with no internal owner.
3. From the criticality register inherited from the 2023 business impact analysis. Nothing measured.
4. No. The same order comes out for 2035 and for 2045. That is the finding.
5. Of the top ten, two have a stated lifetime and eight do not. Emission rate is not recorded anywhere, for any of them.
6. services/genomics (30 years, research contract cl. 9) and archive/hr (50 years, statutory). Both exceed anything we would defend for ten.
7. Genomics: retention cannot be shortened under the contract, so split the archive across two custodians. HR: the 50-year figure comes from a statute requiring retention, not confidentiality — re-read it before treating it as a secrecy requirement.
8. Not estimated. First attempt: roughly four years of exports to the vendor, volume unknown, because egress logs roll after 90 days.
9. 12 August 2026. Source and CI under /srv/apps and /srv/infra. Runtime, HSM contents and third-party systems not observed.
10. Yes: 41 files could not be read (permissions) and 3 archives could not be opened. Reported separately, not counted as scanned.

Where each answer lives

Each question wants a number, and most of those numbers live outside the team running the scan. This is usually why they go unanswered.

Confidentiality lifetimes (1, 6)	The retention schedule, contracts and the legal register. Rarely held by the team that owns the systems, and rarely in one place.
Which systems are unclassified (2)	The difference between the scan output and the classification. Nobody owns this join, which is why the gap is normally invisible.
Basis of the current order (3, 4)	Whoever produced the migration plan. If the answer is a register, ask when it was last revised and against what.
Emission rate (5)	Application logs or the data owner. Not in the cryptographic inventory, and not something a scanner can see.
What has already left (8)	Nowhere. It is an estimate, and it is the first figure anyone will dispute — which is a reason to write it down, not to omit it.
Inventory date and scope (9)	The tool's own manifest, if it emits one. If the scope is not stated in the artefact, it is not stated.
Unread targets (10)	The tool vendor. If they cannot answer, that is the answer.

Why the order matters more than it looks

The guidance converges on ordering by criticality: NIST triages critical business processes first, the NCSC roadmap's 2031 milestone is the “most critical assets”, PMMP groups by risk and process. Singapore's handbook is the most careful of them — it names IT systems with long-lived data as primary harvest-now-decrypt-later targets and asks for impact mapped against likelihood. Even there, long-lived data is a category to include among the crown jewels rather than a quantity to order by.

There is a result about this. No ordering built only on a system's present criticality can minimise capability-conditioned exposure for all capability distributions, shelf lives, emission rates, durations and objective weights. It is not that criticality-first is a poor heuristic; it is that no static ranking of present properties can be optimal across the instances an organisation might actually be in, because the optimal order depends on those quantities jointly.

Proposition 3, in From Q-Day to Exposure Curves: <https://doi.org/10.5281/zenodo.22126410>

What this checklist is not

It does not tell you what your order should be, and it produces no score, rating or risk level. It is a set of questions whose answers you should have before you defend an order to anyone. If several of them cannot be answered today, that is the finding, and it is a more useful one than a number would have been.